個人情報漏えい インシデント対応フロー（ドラフト）

フェーズ別の対応手順・役割別チェックリスト・要決定事項

ドラフト ／ レビュー用 | 実施日 2026-10-02（金）15:00 - 16:00 | 株式会社STANDS

状態: ドラフト。**レビュー前**
根拠: 2026-10-02 実施の机上訓練で見つかった空白8点と、振り返りアンケート（回答10件）
関連: 04_訓練実施報告.pdf（実施報告） / `2026-10-02_action-plan.md`（アクション管理）

> 本文中の **【要決定】** は、このドラフトでは決められない事項です。
> レビューで決めてから確定版にします。一覧は巻末の付録Eにあります。

0. この文書の使い方

何を「インシデント」として扱うか

個人データが、本来見えるべきでない相手に見えた（見えた可能性がある） と思った時点で、
この文書を開きます。

当てはまる例
顧客から「他社のデータが含まれている」と連絡があった
送付・共有したファイルに、宛先以外のデータが入っていた
管理画面やレポートに、本来表示されないはずのデータが出ている
退職者・権限のない人がアクセスできる状態になっていた

3つの原則

#	原則
1	**「疑い」で動く。** 確証は要りません。誤報を許容します
2	**無罰。** ミスをした本人を責めません。隠されるほうが危険です
3	**時刻を残す。** 「何時何分に、誰から、何を聞いたか」。法定報告の起点になります

全体の流れ

> 気づいた人が上げる（〜5分）
> 　└ 専用チャンネルを立て、一次受けが暫定オーナーになる
> 立ち上げ（〜15分）
> 　└ 統括判断者へオーナーを引き継ぐ／役割を配る／証跡を保全する
> 事実確認と止血
> 　└ 調査は2名／影響範囲を確定／止める判断
> 影響範囲と法令判断
> 　└ 該当者の数／報告義務／報告主体
> 顧客対応
> 　└ 誰に・いつ・何を／調査中の伝え方／承認
> 社外報告
> 　└ 委員会への報告／該当者への通知／公表判断
> 収束と記録

---

1. 気づいた人がやること（〜5分）

役職・担当にかかわらず、最初に気づいた人が行います。

- [ ] **疑いの段階で、専用チャンネルを立てる**
- 命名: `incident-{YYYYMMDD}-{短い件名}`（例: `incident-20261002-report-csv`）
- **許可を待たない。** 空振りならあとでアーカイブすれば済みます
- 統括判断者・関係しそうな担当を招集する
- [ ] **時刻と原文を記録する**（受信日時を分単位で、連絡してきた人、原文のまま）
- [ ] **顧客との共有チャンネルで社内の相談をしない**
- Slack Connect では相手に全部見えています。社内の話は専用チャンネルへ
- [ ] **顧客にその場で削除を依頼しない**
- 返すのは「**そのファイルを削除せず、これ以上共有しないでお待ちください**」
- 消されると、何が漏れたかを特定する唯一の現物が失われます
- [ ] 統括判断者へ連絡する（**到達するまで、自分が暫定オーナー**）

> **なぜ専用チャンネルか**: 訓練では作られず、やり取りが3チャンネル5スレッドに分散しました。
> 終了後に一覧を作り直す作業が発生し、「誰が何を決めたか」を追うのに時間がかかりました。

---

2. 立ち上げ（〜15分）

2-1. オーナーを引き継ぐ

一次受け（気づいた人）が暫定オーナー → 統括判断者が入った時点で引き継ぎます。

引き継ぎは**チャンネルに明示的に書く**こと。「ここからオーナーは〇〇さん」と1行書くだけで、
誰が進行を見ているかが全員に分かります。

状況	オーナー
第一報を受けてから、統括判断者が入るまで	**一次受け（暫定）**
統括判断者が入ったあと	**統括判断者**（藤原）
統括判断者が捕まらない場合	【要決定】代理を誰にするか

2-2. 役割を配る

「2名宛に依頼した」だけでは2名体制になりません。 役割を名指しで分けます。

役割	人数	やること
オーナー	1	全体進行。判断を下す。決まったことをチャンネルに書き戻す
調査	**2以上**	**事実を出す役**と、**それを確認する役**に分ける
対外文面	1	顧客向け文面の作成。承認を取る
記録	1	時系列を残す（オーナー兼任可）

> **調査を1名にしない理由**: 原因を作った可能性のある人が一人で事実を確定すると、
> 第三者の確認が入りません。その人が不在・多忙なら調査も止まります。

2-3. 証跡を保全する

オーナーが指示します。 調査より先です。

保全するもの	用途
ダウンロード／アクセスの操作ログ（誰が・いつ・何を取得したか）	**影響範囲を確定できる唯一の根拠**
該当機能のデプロイ記録・変更履歴	いつから発生していたかの特定
顧客から受領したファイルの現物	何が含まれていたかの特定
Slack のメッセージ・共有ファイル	経緯の説明。**消さない**

- 調査のために本番を触るときは、**触る前に「何のために何を見るか」をチャンネルに書く**
- 顧客から受け取った漏えいデータは、**Slack に貼ったままにしない**【要決定】保管場所

2-4. 「知った時」を1つに決める

法定報告の期限は「知った時」から起算します。**組織として1つに決めて記録**してください。
曖昧なままだと、あとから期限を計算できません。

---

3. 事実確認と止血

3-1. 調査の進め方

- [ ] 第一報が来たら、**顧客の誤認を前提にせず、社内でも並行して確認を始める**
- 顧客への確認を待つと初動が遅れます。「顧客に確認する」と「社内で調べる」は同時に
- [ ] 調査は2名。事実を出す役と確認する役を分ける
- [ ] 本番環境を触る前に宣言する（2-3参照）

3-2. 影響範囲を確定する

次の2つが揃って初めて件数が出ます。

必要な情報	確認先
いつから発生していたか	デプロイ記録・変更履歴
その間に誰が取得／閲覧したか	操作ログ

「指摘してきた1社」で終わらせないこと。 同じ機能を使っている他の顧客、
さらに**その顧客に自社データを見られた側**も影響範囲に入ります。

3-3. 止血する

選択肢	判断の目安
修正してリリース	修正の見込みが短時間で立つ場合
機能を一時停止する	修正に時間がかかる場合、または原因が特定できていない場合

- 判断者: 【要決定】
- **目安**: 第一報から30分以内に修正の見込みが立たなければ、停止を検討する【要決定】
- 修正リリースは**必ずレビューを通す。** 急いだ修正が二次被害を生みます

---

4. 影響範囲と法令判断

> ここでの整理は社内判断の出発点です。**最終判断は法務・顧問弁護士に確認**してください。

4-1. 件数の数え方

行数ではなく「該当者（法律上の「本人」）の数」で数えます。

4-2. 個人情報保護委員会への報告義務

以下の**いずれか**に当たる場合、報告義務が生じます（**「おそれ」の段階で足ります**）。

#	類型	判断のポイント
1	要配慮個人情報が含まれる	**1件でも対象。** 病歴・障害・犯罪歴など
2	財産的被害のおそれ（クレジットカード番号等）	1件でも対象
3	不正の目的によるおそれ（不正アクセス等）	1件でも対象
4	**該当者の数が1,000人を超える**	件数で判断

> **注意**: 顧客が任意に値を入れる項目（カスタムクエリ等）に要配慮個人情報が入っていた場合、**件数に関係なく類型1で報告対象**になります。中身を把握していないと判断できません。

4-3. 報告するのは誰か

契約上の立て付けで変わります。

立て付け	報告主体
当社が顧客から**委託を受けて**取り扱っている	委託元（顧客）が報告義務を負う。**当社は委託元へ通知することで、当社の報告義務が免除され得る**
当社が**自ら取得した**個人情報	**当社が報告主体**

- 参照先: 【要整備】契約類型の一覧（どの顧客がどちらか）
- **混入元（データの持ち主）への通知を忘れないこと。** 訓練では議題に上がりませんでした

4-4. 期限

種別	期限
速報	「知った時」から速やかに（概ね3〜5日以内）
確報	「知った時」から30日以内（類型3は60日以内）

4-5. 相談先

【要決定】法務・顧問弁護士への相談ルートと連絡先。**夜間・休日に捕まるか**も含めて。

---

5. 顧客対応

5-1. 誰に伝えるか

対象	伝え方
直接影響があった顧客（データが混入した／見られた）	個別に連絡
影響の可能性がある顧客	個別に連絡
その他の顧客	全体への周知（必要に応じて）

連絡先・連絡手段（Slack / Chatwork / Teams / メール）は顧客ごとに異なります。
【要整備】顧客連絡先台帳を参照。

5-2. いつ伝えるか

原因が特定できていなくても、影響の可能性が確認できた時点で第一報を出します。
確定を待つと、顧客が他のルートで知ることになります。

5-3. 調査中に何を伝えるか

確定していることと、調査中のことを分けて書きます。推測は書きません。

書くこと	書き方
確認できている事実	言い切る
まだ分からないこと	**「現在調査中」と明記する。**空欄にしない
次の連絡	**いつまでに、何を報告するか**を書く

> 「調査中」と書くことは不誠実ではありません。**分からないことを分かったように書くほうが問題です。**

5-4. 文面のテンプレート

【要整備】第一報 / 続報 / 最終報告のテンプレート。

障害報告と同じトーンにしないこと。 機能が使えない不具合と、個人データが外部に見えた事象は
顧客にとって重大度が違います。

5-5. 誰が承認するか

【要決定】

種別	承認者（案）
通常の障害報告	現行どおり（エンジニア＋ビジネス側のチェック）
個人データが関わる報告	統括判断者は必須。**経営層の確認を要するかは要決定**

---

6. 社外報告

- [ ] 個人情報保護委員会への報告（速報・確報）※報告主体の確認後
- [ ] **該当者への通知**
- 当社は該当者の連絡先を持っていません（氏名とIDのみ）。
  委託元である顧客を経由した通知になります。依頼の形と文面を決めてから動きます
- [ ] 公表するかの判断 — 【要決定】権限者
- [ ] 報道対応の窓口 — 【要決定】

---

7. 収束と記録

- [ ] 時系列を確定する（専用チャンネルのログから復元できます）
- [ ] 「知った時」「報告した時」「止血した時」を明記する
- [ ] 社内報告書をまとめる
- [ ] 原因に応じた点検・改善を起票する
- [ ] **専用チャンネルはアーカイブする（削除しない）**

---

8. 平時に保っておくもの

事故が起きてから作るのでは間に合いません。

#	保つもの	現状
1	顧客連絡先台帳（顧客 × プロダクト × 担当CS × 一次連絡先 × 上長 × 連絡手段）	【要整備】
2	夜間・休日の連絡網（Slack以外の手段）	【要整備】
3	顧客向け文面テンプレート（第一報 / 続報 / 最終報告）	【要整備】
4	契約類型の一覧（委託 / 自社取得）	【要整備】
5	エンジニアチームの役割分担・窓口表	【要整備】
6	権限表（止血の判断 / 文面の承認 / 公表の判断）	【要決定】
7	扱うデータ項目の個人情報該当性の整理	【要整備】

付録A 一次受け（CS）チェックリスト

第一報を受けたら、上から順に。

- [ ] **専用チャンネルを立てる**（`incident-{日付}-{件名}`）。許可を待たない
- [ ] 受信時刻・連絡元・原文を記録する
- [ ] 統括判断者へ連絡する（**届くまで自分が暫定オーナー**）
- [ ] 顧客へ返す: **「削除せず、これ以上共有しないでお待ちください。確認してご連絡します」**
- いつまでに何を返すかも伝える
- [ ] **顧客との共有チャンネルに社内の相談を書かない**
- [ ] エンジニアへ調査を依頼する（**2名を名指しで**。役割も分けて伝える）
- [ ] 他の顧客から同様の連絡が来ていないか、CSチームへ確認を依頼する
- [ ] 顧客から受け取ったファイルの置き場所を確認する（Slackに貼ったままにしない）

迷ったら: 判断を抱え込まず、チャンネルに「ここが決められない」と書く。

付録B 統括判断チェックリスト

- [ ] **オーナーを引き継ぐ**（チャンネルに「ここからオーナーは自分」と書く）
- [ ] **役割を配る**（調査2名／対外文面／記録）。名指しで
- [ ] **証跡保全を指示する**（操作ログ・デプロイ記録・現物・Slackログ）
- [ ] **「知った時」を1つに決めて記録する**
- [ ] 止血の判断（修正 or 一時停止）。**30分で見込みが立たなければ停止を検討**
- [ ] 報告義務の判断に着手する（該当者の数／類型／**報告主体は委託か自社取得か**）
- [ ] 顧客への第一報を承認する
- [ ] 法務・顧問弁護士への相談要否を判断する
- [ ] **決まったことをチャンネルに書き戻す**（口頭・ハドルで決めた分も必ず）

付録C 調査（エンジニア）チェックリスト

- [ ] **2名で入る。** 事実を出す役と、確認する役を分ける
- [ ] **本番を触る前に、何のために何を見るかをチャンネルに書く**
- [ ] 発生期間を特定する（デプロイ記録・変更履歴）
- [ ] **誰が取得／閲覧したかを特定する**（操作ログ）
- ログが無い場合は「**確認できない**」と明記する。曖昧にしない
- [ ] 影響範囲を広げて確認する
- 同じ機能を使った他の顧客 → **その顧客にデータを見られた側の顧客**
- 同じ原因が他の機能にも及んでいないか
- [ ] 止血する（修正 or 停止）。**修正は必ずレビューを通す**
- [ ] 分かったことを**そのつどチャンネルに書く**（確定／未確定を分けて）

付録D 対外文面チェックリスト

- [ ] 宛先を確認する（直接影響 / 可能性あり / 全体周知）
- [ ] 連絡手段を台帳で確認する（Slack / Chatwork / Teams / メール）
- [ ] **確定していることと調査中のことを分けて書く**
- [ ] **次にいつ、何を報告するかを書く**
- [ ] 障害報告のトーンで書いていないか見直す
- [ ] 承認を取る（統括判断者は必須。経営層の要否は【要決定】）
- [ ] 送付後、**送った文面と時刻をチャンネルに残す**

付録E 要決定・要整備の一覧

このドラフトでは決められなかった事項です。レビューで決めてください。

#	項目	誰が決めるか	関連アクション
1	統括判断者が捕まらない場合の代理	統括判断者	#13
2	止血（機能停止）の判断者と、判断の目安時間	統括判断者	#4
3	顧客向け文面の承認者（経営層の確認要否）	統括判断者・経営層	#7
4	公表の判断権限者・報道対応の窓口	経営層	#7
5	法務・顧問弁護士への相談ルートと連絡先（夜間含む）	統括判断者	—
6	顧客から受領した漏えいデータの保管場所	統括判断者	#2
7	顧客連絡先台帳の整備（誰が維持するか）	CS	#15
8	夜間・休日の連絡網	全体	#17
9	文面テンプレートの作成	CS	#7
10	契約類型（委託／自社取得）の一覧	統括判断者	#3
11	エンジニアチームの役割分担・窓口表	エンジニア	#18
12	扱うデータ項目の個人情報該当性の整理	統括判断者	#5 / #6